Inside the server: one request's path

Layers are axum middleware; the privacy layer wraps every route, so every answer passes it on the way out.

guard (server.rs)

security headers on every answer (CSP, frame rules, nosniff, no-referrer, no-store on the API); X-Medorama: 1 required on every changing API request

privacy layer (server.rs privacy, gate.rs)

in: finds the session's user once; Privacy Mode unless the user has the PHI permission and turned it off (POST privacy)
out, in Privacy Mode: JSON through the gate; files only if the gate cleared them; anything else refused (fail closed)

API /api/v1

patients, report, detail
cohorts, databases
imports, review (admins)
users, audit (admins)
files: patients/{id}/file/…

Gateway /viewer/

allow-list of viewer API v1
per-user browse and open
rules; Privacy Mode: tokens,
times translated, no
folders

Pages /, /viewers/

the Medorama page and the
ECG and PACS viewers:
static files, no data,
embedded in the binary

Command line medorama

init, import, serve, run,
work, users, addons;
the local account is the
catalog's owner

gate.rs

dictionary of identifiers
placeholders, file tokens
table cells, notes

deid.rs

dates moved back
(per patient), ages 90+
WFDB, EDF headers; MUSE XML

dicom.rs

DICOM headers (PS3.15
Basic Profile), pixels
copied byte for byte

pseudonyms.rs

MO-XXXX-XXXX, random,
stored, check character,
aliases on merges

patient/, cohorts/

the patient page, search,
cohort definitions,
exports

tables.rs, imports.rs

databases in, columns
kept as imported,
identity, removal

users.rs

Argon2id, sessions
(SHA-256 of a random
token), roles, PHI

jobs.rs, actions.rs

queue, workers, indexing,
plug-ins as processes
(pseudonyms only)

catalog database (db.rs, sql/: SQLite or PostgreSQL, migrations, owner-only files, optional SQLCipher; identifiers only in their tables)